

CHALLENGE 6: Uso non corretto della proprietà fillable nei modelli

Attacco Mass Assignment:

L'applicazione include una pagina di modifica profilo che permette di aggiornare nome, email e password.

Tuttavia, il modello `User` ha la proprietà `$fillable` configurata in modo errato, includendo campi sensibili come `is_admin`, `is_revisor`, `is_writer`.

Attacco eseguito:

- 1) Accesso come utente writer (writer@test.com)
- 2) Modifica del form con DevTools, aggiungendo:

```
<input type="hidden" name="_token" value="9g25sKpYvZ1BnXWBOi42dIIDqxnHzAUtShqBw3hr">
<input type="hidden" name="is_admin" value="1">
```

Invio della richiesta, privilege escalation riuscita

Accesso alla dashboard admin e visualizzazione dei dati finanziari

The screenshot shows the application interface. At the top, there is a navigation bar with 'The Aulab Post', 'Work with us', 'Write you Article', and 'Hi, Writer Test'. A search bar is also present. Below the navigation bar, a green banner displays 'Profilo aggiornato!'. A dropdown menu is open, showing options: 'Profile', 'Admin panel', 'Writer panel', and 'Logout'. The 'Admin panel' option is highlighted. Below the dropdown, the 'Modifica P' (Modify Profile) form is visible. It contains fields for 'Nome' (filled with 'Writer Test'), 'Email' (filled with 'writer@test.com'), and 'Password' (with a hint 'lascia vuoto per non cambiare'). A 'Salva' button is at the bottom of the form.

Mitigazione:

Come richiesto dalla challenge, ho corretto la proprietà \$fillable nel modello User.php, includendo solo i campi gestiti dal form:

```
protected $fillable = [  
    'name',  
    'email',  
    'password'  
];
```

Risultato:

I campi is_admin, is_revisor, is_writer non sono più assegnabili
Un attaccante che riprova lo stesso exploit ottiene:
Profilo aggiornato (nome/email)
Ma nessun cambio di ruolo
Verifica con Tinker: is_admin => null

Not Authorized

The Aulab Post

Write an amazing article

Conclusione:

La corretta configurazione di \$fillable è fondamentale per prevenire attacchi di Mass Assignment.

Solo i campi effettivamente gestiti dall'utente devono essere inclusi.